Gate 11 — Auth MVP (Credentials)

Goal

Wire the existing Django auth surface into the Next.js frontend using NextAuth v4 with the Credentials provider, so that researchers can self-register and verified coordinators can sign in to read tier-gated data through their own session — no service tokens mailed around. Ship behind `NEXT_PUBLIC_FEATURE_AUTH` so the entire surface can be hidden if anything regresses the week before ABQ. Backwards compatibility with the existing `COORDINATOR_API_TOKEN` SSR path is non-negotiable; this gate does not deprecate it.

Scope

In scope. NextAuth v4 install + Credentials provider; `/login`, `/signup`, `/verify`, `/account` pages; JWT carrying `tier` + `drfToken` + `tierFetchedAt` with the 5-minute `/me/` refresh from the architecture spec §4; `apiFetch` gains an optional `authToken` argument; SSR forwarding wired into the species map locality fetch and `/dashboard/coordinator`; flag-gated Login / Sign Up / Logout nav; middleware guard on `/account` (and `/dashboard/coordinator` redirect-to-login when no session and no service token); end-to-end Playwright covering signup → verify → login → tier-gated read; ops docs.

Out of scope (explicit, do not creep). ORCID provider; MFA; magic-link; account linking UI; institutional SSO/SAML; `COORDINATOR_API_TOKEN` deprecation; hobbyist-form re-plumbing; tier-change notification emails; "resend verification" endpoint (BA recommends users re-register on expired tokens for MVP); self-service tier promotion (admin-only, Django admin path stays as-is).

Decision lock — coordinator dashboard auth source

The architecture spec §5 says the coordinator dashboard SSR keeps using `COORDINATOR_API_TOKEN` "for now." The user's gate scope inverts that and the BA flagged the contradiction. **Lock the user's reading: session-first, service-token-fallback.**

Concrete fallback contract for `frontend/lib/coordinatorDashboard.ts` (and any other SSR caller into `TierOrServiceTokenPermission` endpoints):

1. Call `getServerSession(authOptions)`.
2. If `session?.drfToken` is present, send `Authorization: Token ${session.drfToken}`.
3. Else if `process.env.COORDINATOR_API_TOKEN` is set, send `Authorization: Bearer ${COORDINATOR_API_TOKEN}` (the existing service-token branch on `TierOrServiceTokenPermission`).
4. Else send no Authorization header. The endpoint will 401/403 and the panel renders the existing "token not configured" banner — same behavior as today, no regression.

`TierOrServiceTokenPermission` already accepts both branches, so the swap is mechanical and the fallback chain is robust to staging/prod env-var skew.

Preconditions (verify before C1)

- Branch `gate/11-auth-mvp` cut from `main`. Never commit to `main`.
- `NEXT_PUBLIC_API_URL`, `FRONTEND_BASE_URL`, `DEFAULT_FROM_EMAIL`, `EMAIL_BACKEND` (and vendor credentials) all set in dev and staging.
- `NEXTAUTH_SECRET` and `NEXTAUTH_URL` set in dev and staging. Prod values added but feature flag stays OFF.

- A seeded Tier 3 user exists in dev/staging fixtures so the e2e test in C9 has something to log into. If one is missing, add it to the existing accounts fixture before C5.

Deliverables

Frontend pages (new).

- `frontend/app/login/page.tsx` — email/password form, `?verified=1` flash banner, `?callbackUrl=…` honored against the open-redirect allow-list.
- `frontend/app/signup/page.tsx` — email/name/password form. Posts via a server action (or route handler) to `/api/v1/auth/register/` so the deterministic origin/IP reaches Django's rate limiter. `institution_id` field is **out of scope** this gate per BA Open Question 2 — defer.
- `frontend/app/verify/page.tsx` — reads `?token=…`, POSTs to `/api/v1/auth/verify/`, redirects to `/login?verified=1` on success, renders generic "link invalid or expired" on failure with copy pointing to re-register.
- `frontend/app/account/page.tsx` — server component. Renders email, name, tier badge ("Researcher · Tier 2", "Coordinator · Tier 3", etc.), Logout button. **No DRF token in any prop, hook, or serialized JSON.**

Frontend lib + middleware (new + edited).

- `frontend/lib/auth.ts` — `authOptions` export (Credentials provider, `jwt` / `session` callbacks, 5-min `/me/` refresh, prod cookie config from architecture §3).
- `frontend/app/api/auth/[...nextauth]/route.ts` — NextAuth handler.
- `frontend/lib/api.ts` — `apiFetch` gains an optional `authToken` argument. Anonymous calls are unchanged. **Do not** change the default behavior; only add the new option.
- `frontend/lib/mapLocalities.ts` — pass `session?.drfToken` through.
- `frontend/lib/coordinatorDashboard.ts` — implement the session-first / service-token-fallback chain locked above.
- `frontend/middleware.ts` (new) — guard `/account`. For `/dashboard/coordinator`, only redirect to `/login?callbackUrl=…` when neither a session token nor `COORDINATOR_API_TOKEN` is available; otherwise let SSR run and let the API decide.

Frontend components (edited).

- `frontend/components/NavLinks.tsx` — append flag-gated `Login` / `Sign Up` / `Logout` / `Account` items based on `NEXT_PUBLIC_FEATURE_AUTH` and session presence. The flag is read in a server component wrapper or via build-time env (it is a `NEXT_PUBLIC_*` var); `NavLinks.tsx` itself stays a client component but receives `authVisible` and `session` props from `SiteHeader`.
- `frontend/components/SiteHeader.tsx` — fetch session via `getServerSession(authOptions)`, pass to `NavLinks`. Header stays a server component.

Backend. No changes. (Architecture §10 mentions optionally tightening `verify/` to return `access_tier`. Defer — not required for this gate's flow since login immediately follows verify.)

Env vars (new).

- `NEXTAUTH_SECRET` (server-only). Required.
- `NEXTAUTH_URL` (server-only). Required.
- `NEXT_PUBLIC_FEATURE_AUTH` — `"true"` to expose auth nav; default unset/`"false"`.

Docs.

- `CLAUDE.md` — short "Auth (Gate 11)" subsection: where authOptions live, how SSR forwards tokens, the session-first/service-token-fallback chain, the no-DRF-token-in-React rule.
- `OPERATIONS.md` — secrets section: list `NEXTAUTH_SECRET`, `NEXTAUTH_URL`, `NEXT_PUBLIC_FEATURE_AUTH` alongside existing `COORDINATOR_API_TOKEN`, `NEXT_REVALIDATE_SECRET`. Rotation cadence: annual for `NEXTAUTH_SECRET`, on personnel change for shared secrets. Document the Vercel-preview-stays-anonymous fact (architecture §9).

Acceptance criteria

The full Given/When/Then set lives in `docs/planning/business-analysis/auth-gate-11.md`. The PM additions and gate-level criteria are below; the BA stories are normative for individual flows.

Story-level (from BA, summarized — see BA doc for the full text).

- **Story 1** — Researcher signs up, verifies, logs in. AC 1.1–1.5.
- **Story 2** — Coordinator logs in and gets exact map coordinates. AC 2.1–2.5. AC 2.3 is locked to the session-first / service-token-fallback contract above.
- **Story 3** — Anonymous visitor sees the same public site. AC 3.1–3.4. The flag-OFF behavior in 3.3 is verified by a unit test that mounts `NavLinks` with `authVisible=false` and asserts no Login/Sign-Up nodes are rendered.
- **Story 4** — Operator promotes Tier 2 → Tier 3 via Django admin; the change propagates to the user's session within 5 minutes via the `/me/` refresh.
- **Story 5** — Existing `COORDINATOR_API_TOKEN` callers keep working. AC 5.3 is the explicit "session token wins, service token fallback" assertion.

Cross-cutting (from BA §Cross-cutting). Rate limiting, enumeration resistance, cookie security, 30-day rolling session, Logout deletes the DRF Token server-side, DRF token never reaches the browser, open-redirect allow-list. All five carry forward unchanged.

Gate-level (PM additions).

- CI green on the existing matrix (`backend` pytest, `frontend` vitest, lint, type-check, ruff at `--line-length 100`).
- Playwright e2e in `frontend/e2e/auth.spec.ts` passes against staging, covering: signup → verify (exercise the email link via the dev mailbox or a `signer.sign` shortcut in test mode) → login → load `/map` and assert the SSR request to `SpeciesLocality` detail carried `Authorization: Token …` (assert via Playwright network interception or a server-side test fixture, not by reading the cookie from JS).
- Frontend production bundle size delta ≤ 25 KB gzip on the routes that did not previously import auth code (NextAuth ships its own JWT — measure via `next build` output or `@next/bundle-analyzer`). The `/login`, `/signup`, `/verify`, `/account` routes carry the auth bundle and are excluded from the budget.
- `npm run lint` and `npm run typecheck` pass with no new warnings related to NextAuth typings.
- Security-reviewer agent invoked on the merged branch; checklist references architecture §13 — do not duplicate items, just confirm each line.
- Code-quality-reviewer agent invoked.
- `OPERATIONS.md` updated; `CLAUDE.md` updated; both committed in C10.

Sequencing / commit plan

Order matters because the partway-through state must keep the public site working. Each commit lists the primary file or two an implementer should open first.

- **C1 — Feature flag scaffold + env vars + middleware skeleton.** Add `NEXT_PUBLIC_FEATURE_AUTH` plumbing; create `frontend/middleware.ts` as a no-op pass-through (matcher set up but no redirects yet); add the new env vars to `.env.example`. Primary files: `frontend/middleware.ts`, `frontend/.env.example`.
- **C2 — NextAuth route handler + Credentials provider + JWT/session callbacks.** Install `next-auth@4.24.x` (pinned, no caret). Implement `authOptions` per architecture §3–§4 including the 5-minute `/me/` refresh and 401-clears-session rule. Primary files: `frontend/lib/auth.ts`, `frontend/app/api/auth/[...nextauth]/route.ts`, `frontend/package.json`.
- **C3 — `apiFetch` gains `authToken` (no UI yet).** Additive change; existing call sites untouched. Add unit tests mirroring `frontend/lib/api.test.ts` patterns for the new branch. Primary file: `frontend/lib/api.ts`, `frontend/lib/api.test.ts`.
- **C4 — SSR forwarding wired into species localities + coordinator dashboard.** Implement the session-first / service-token-fallback chain in `coordinatorDashboard.ts`. Pass `session?.drfToken` from server components into `apiFetch`. Primary files: `frontend/lib/mapLocalities.ts`, `frontend/lib/coordinatorDashboard.ts`.
- **C5 — `/login` page + form + integration test.** Form posts via NextAuth's `signIn("credentials")`. Honor `?callbackUrl=` against the allow-list. `?verified=1` renders the flash banner. Primary file: `frontend/app/login/page.tsx`.
- **C6 — `/signup` + `/verify` pages + email link flow.** Signup posts to Django register from a server action so the rate-limit IP is the Next.js node, not the browser. Verify reads `?token=` and POSTs to `/auth/verify/`. Primary files: `frontend/app/signup/page.tsx`, `frontend/app/verify/page.tsx`.
- **C7 — `/account` page + Logout.** Server component reads session, renders profile + tier badge. Logout button posts to `/auth/logout/` (deleting the DRF Token) **and** calls `signOut()` (clearing the cookie). Both must fire — a logout that only clears the cookie is a bug per BA cross-cutting. Primary file: `frontend/app/account/page.tsx`.
- **C8 — Nav links behind feature flag.** `SiteHeader` reads `getServerSession`, passes `authVisible` (from `NEXT_PUBLIC_FEATURE_AUTH`) and `session` to `NavLinks`. Primary files: `frontend/components/SiteHeader.tsx`, `frontend/components/NavLinks.tsx`.
- **C9 — Playwright e2e: signup → verify → login → tier-gated read.** Add `frontend/e2e/auth.spec.ts`. Use a test-mode helper that pulls the verification token directly from a DB fixture or a Django management command rather than scraping email — keeps the test deterministic. Primary file: `frontend/e2e/auth.spec.ts`.
- **C10 — Docs.** `CLAUDE.md` auth subsection, `OPERATIONS.md` secrets rotation entry, Vercel-preview-stays-anonymous note. Primary files: `CLAUDE.md`, `OPERATIONS.md`.

After C10: invoke security-reviewer and code-quality-reviewer agents. Address feedback before requesting human review.

Test strategy

Unit (Vitest, `frontend/lib/*.test.ts`).

- `authorize()` shape: 200 returns `{id, email, tier, drfToken}`; 401 returns `null`; 429 returns `null` (no distinct UI signal).
- `jwt` callback: persists `tier` and `drfToken`; refreshes on TTL expiry; clears the JWT on `/me/` 401. Mock `/me/` — no real Django round-trips.
- `session` callback: projects `tier` and `drfToken` onto the session; **assert** `drfToken` is on the server-only object (architecture §5 — never in the React tree).

- `apiFetch` `authToken` branch: header is `Authorization: Token ${token}` ; absent when `authToken` is undefined.
- `coordinatorDashboard.ts` fallback chain: session present → uses session token; session absent + service token present → uses service token; both absent → no Authorization header.
- `NavLinks` flag-gated rendering with `authVisible=false` (no Login/Sign-Up nodes), `authVisible=true && !session` (Login + Sign-Up nodes), `authVisible=true && session` (Account + Logout nodes).

Integration (Vitest, `backend/accounts/tests/*` — already exist, do not refactor). Existing `test_auth.py` patterns cover rate-limiting, enumeration resistance, expired tokens. Confirm green on this branch — no regressions from frontend changes.

E2E (Playwright, `frontend/e2e/auth.spec.ts`).

- Anonymous visitor loads `/` , `/species/` , `/map/` , `/dashboard/` . No Authorization header on any SSR fetch (assert via mock-server interception). All routes render.
- Anonymous visit to `/account` redirects to `/login?callbackUrl=/account` .
- Signup → verify → login → `/account` → assert tier badge text. Then visit `/map` and assert the `SpeciesLocality` detail SSR fetch carried `Authorization: Token …` (intercept at the test reverse-proxy or use a Playwright route handler).
- Logout → cookie cleared → `/account` redirects to `/login` . Assert that the user's DRF Token is gone from the database (via a small Django management command or an admin-token-driven `/me/` that returns 401).
- Flag OFF: nav has no Login/Sign-Up links; `/login` and `/signup` direct URLs still resolve.

Adversarial (test-writer agent, anchored to architecture §12).

- Login rate-limit: 6 wrong attempts in 15 minutes returns the same generic copy as a 401 (no "try again later" leak).
- Verification token >48h returns generic invalid-link copy; assert no info-leak.
- Open-redirect via `?callbackUrl=https://evil.example` . Allow-list rejects, redirect lands on `/` .
- Open-redirect via the email verification URL — assert the post-verify redirect target is also allow-listed.
- Deactivated user with a still-valid JWT: next `/me/` refresh inside the 5-min window must 401 and force re-login.
- Service-token regression: existing `COORDINATOR_API_TOKEN` -only flow (no session) still authenticates and returns the same data shape (Story 5 AC-5.4).
- Session token wins over service token when both are available (Story 5 AC-5.3).

Risks + mitigations

- **Email deliverability vendor not selected by C6.** Without a working `EMAIL_BACKEND` , signup-verify is untestable end-to-end. **Mitigation:** Aleksei picks the vendor before C6 starts; C6 can develop against the console backend if the vendor decision slips, but C9 cannot ship until a real backend is wired in staging. Block merge on this.
- **NextAuth typings drift in 4.24.x patch versions. Mitigation:** pin (no caret), pin in `package-lock.json` , and add a `package.json` `overrides` entry if a transitive bumps it.
- **Cookie domain mismatch between Vercel preview and `*.malagasyfishes.org` . Mitigation:** architecture §9 — preview stays anonymous, document in `OPERATIONS.md` . UAT happens on `staging.malagasyfishes.org` . Do not try to make preview authenticated.

- **`apiFetch` change accidentally regresses anonymous routes. Mitigation:** C3 adds `authToken` as an optional argument with no default behavior change. Unit tests cover both the `authToken=undefined` (existing) and `authToken=…` (new) branches before any caller is touched.
- **5-minute `/me/` refresh hammers Django on a busy session. Mitigation:** TTL is per-JWT, not per-request — the refresh fires only when `now - tierFetchedAt > 300`. Throughput is fine. Architecture §4 already locked this; no change.
- **Implementer creeps in ORCID, MFA, or magic-link. Mitigation:** the Out of Scope section below is enumerated and the security-reviewer agent will reject additions not in this gate's scope.
- **`COORDINATOR_API_TOKEN` env var misconfigured in prod after the swap. Mitigation:** the fallback chain is order-preserving; if neither token resolves, the panel renders the existing "token not configured" banner. No silent failure.

Rollout plan

- Default `NEXT_PUBLIC_FEATURE_AUTH=false` in prod through the merge of C10.
- After security-reviewer + code-quality-reviewer sign-off, deploy to staging with the flag ON. Soak for at least 72 hours: smoke-test signup, verify, login, logout, deactivation, tier promotion (via Django admin) all on the staging host.
- Pre-ABQ flip: with at least 5 business days remaining before June 1, set the flag ON in prod. Aleksei monitors for 24 hours.
- **Rollback recipe.** If anything regresses: set `NEXT_PUBLIC_FEATURE_AUTH=false` in Vercel prod env and trigger a redeploy (no code revert needed). Login/Signup/Logout/Account nav disappears; `/login`, `/signup`, `/verify`, `/account` direct URLs continue to resolve for UAT but are not advertised; anonymous public surface is unchanged; the `COORDINATOR_API_TOKEN` SSR path continues to work because the fallback chain catches the absent session.
- If a deeper rollback is needed (e.g. a NextAuth bug breaks SSR for anonymous users), revert the merge commit. The branch is a single PR — revert is mechanical.

Out of scope (explicit)

- ORCID provider, "Sign in with ORCID", "Connect ORCID" (Gate 12).
- MFA / TOTP.
- Magic-link / passwordless email.
- Account linking UI.
- Institutional SSO / SAML.
- `COORDINATOR_API_TOKEN` deprecation. The token continues to work.
- "Resend verification" endpoint. Expired-link users re-register (BA Open Question 1, recommended path).
- `institution_id` field on the signup form (BA Open Question 2, deferred).
- Tier-change notification emails (BA Story 4 Open Question, deferred).
- Hobbyist-form re-plumbing.
- Self-service tier promotion. Admins promote via Django admin (Story 4).

Dependencies + handoffs

- **Email vendor decision.** Aleksei picks Mailgun / Resend / SendGrid before C6 starts. Blocks Gate 11 sign-off (architecture Appendix A).
- **`NEXTAUTH_SECRET` generation.** Aleksei runs `openssl rand -hex 32` per environment and adds the value to dev `.env.local`, the staging env store, and the prod env store. Required before C2 can be merged to staging.

- **`NEXTAUTH_URL` per environment.** `http://localhost:3000` (dev), `https://staging.malagasyfishes.org` (staging), `https://malagasyfishes.org` (prod).
- **Tier 3 fixture user.** Add to the existing accounts fixture before C5 if not already present.
- **ORCID OAuth app registration.** Deferred to Gate 12. Do not register the app yet — the credentials would sit unused.
- **Security-reviewer agent.** Invoke after C10. Anchor to architecture §13; do not re-derive the checklist.
- **Test-writer agent.** Invoke after C10 for the adversarial pass listed under Test Strategy.